



8.3 Student Guide: Follow Data Through Layers 2, 3, and 4

Overview

On the third day of our introduction to networking, you will learn how to gather data from specific networks using enumeration.

Then, we will move through three layers of the OSI model—Layer 2 (the Data Link layer), Layer 3 (the Network layer), and Layer 4 (the Transport layer). You will learn the following tools and protocols related to each layer: Layer 2 (ARP), Layer 3 (ping and traceroute), and Layer 4 (TCP and UDP). Finally, you will perform a SYN scan to search for open ports on a network.

Class Objectives

By the end of class, you will be able to:

- Define enumeration as a set of methods used by security professionals and hackers to determine network vulnerabilities.
- Use Wireshark to visualize and analyze ARP activity, including ARP spoofing.
- Use ping to determine if hosts are up and reachable.
- Use traceroute to troubleshoot networking communication issues between two devices.
- Define and distinguish TCP and UDP.
- Analyze TCP traffic in Wireshark.
- Analyze SYN scans to determine the availability of ports on a network.

Lab Environment

- You will use your Networking virtual machine for today's activities.

Slideshow

The slides for today can be viewed on Google Drive here: [8.3 Slides](#)

01. Welcome and Introduction

In the previous class, we covered the following:

- Protocols are standardized rules that dictate how data is communicated.
- Ports assist with where the data is transmitted to and from, with respect to the server and client.
- The seven layers of the OSI model conceptualize how data is communicated across a network.
- Wireshark is a powerful utility for in-depth analysis of network packets.

In this lesson, we will cover the following concepts:

- The process of gathering data for a specific network, known as enumeration.
 - The Layer 2 Data Link protocol ARP, used to transfer network traffic within a local network.
 - The Layer 3 Network utilities `ping` and `tracert`, used by network and security professionals to diagnose network issues.
 - The Layer 4 Transport protocols TCP and UDP and how TCP establishes a connection with a three-way handshake.
 - SYN scans and how both security professionals and attackers can use this method to determine the state of ports in a network.
-

02. Introduction to Enumeration

As we've discussed, hackers will often try to gain unauthorized access to a network. It's the job of security professionals to secure networks by identifying network vulnerabilities.

- A hacker discovers that a server with payroll data accidentally has an open port 22, for SSH.

- This lets the hacker gain unauthorized access to the company's network, allowing them to steal or alter important data such as social security numbers or salary information.
- The security professional must determine which unauthorized ports are open and then close them, protecting the integrity of the company.

The methods that hackers use to find and exploit vulnerabilities are often the same ones that security professionals use to find and patch vulnerabilities.

One prominent method used by both attackers and security professionals is enumeration.

- Enumeration is the process of gathering data for a specific network, usually for the purpose of finding ways to gain access to that network.
- Enumeration can provide the following information:
 - Physical addresses of devices in a network
 - The IPs and ports that are used or accessible
 - Network devices and network security devices used

In today's class, we will introduce how security professionals use protocols and tools that exist in Layers 2, 3, and 4 of the OSI model to enumerate a network.

03. Address Resolution Protocol (ARP) (Layer 2: Data Link)

The reason we are covering the OSI layer protocols and tools is because they contain vulnerabilities that can be exploited by hackers to gain unwanted access to networks.

- To harden networks, we need to know how these protocols work and how attackers take advantage of them.
- We'll begin with the Layer 2 protocol, Address Resolution Protocol (ARP).

A Brief Introduction to ARP

Before looking closely at ARP, we'll recap the process used by networks to communicate with each other over the internet:

- When devices communicate from one network to another, they often send communications across the internet.
 - This type of network is known as a wide area network (WAN).
- The data then travels across the internet to its destination network.
 - We refer to this destination network as a local area network (LAN).
- Once the data reaches the LAN, it still has to be transmitted to its final destination on the LAN.

Once on a LAN, the data is routed through network devices called switches to a physical machine address.

- The physical address, also referred to as the media access control (MAC) address, is a sequence of numbers and letters such as 00:0c:29:0f:71:a3 that identifies the destination computer's unique hardware number.
- Without a MAC address, the data may reach the LAN, but not know where to next transmit the data.

To ensure data gets from the LAN to the machine, the ARP, at Layer 2 data link, maps a physical machine (MAC) address to an IP address within a LAN. This mapping occurs through an ARP request and reply process.

The ARP request and reply process includes the following:

- The network device that is transmitting the data broadcasts an ARP request to all devices within its network to find the physical address that matches the IP address.
- The device that owns that IP address recognizes its IP in the ARP request. It sends an ARP reply with its MAC address, so the network knows where to route the data.
- The mapping of the MAC address to the IP address is added into the ARP cache. An ARP cache is a table of entries containing ARP records.
- The next time that data comes in looking for this specific destination device, it does not need to broadcast another ARP request. Because the network already has the record in its cache, it can automatically route the data.

Entries added to the ARP cache are called dynamic ARP entries, meaning they can be changed with future ARP replies.

- Dynamic ARP entries only stay in the ARP cache for a limited period of time, known as the ARP cache timeout.
- When the ARP cache timeout expires, the record is removed from the ARP cache and any future requests for the host require a new ARP request.

Wireshark allows us to visualize ARP requests and responses.

- First, we'll filter for all ARP packets in a .pcap file.
- This filter will show us the request from the source host, which will include a MAC address, associated with a specific IP address, to which the data needs to be transmitted.
- If the request can be successfully answered, we'll see a response from the owner of the IP address, which will contain the device's MAC address.

ARP Wireshark Demo

In the upcoming demo, we'll analyze a .pcap file to visualize ARP requests and responses.

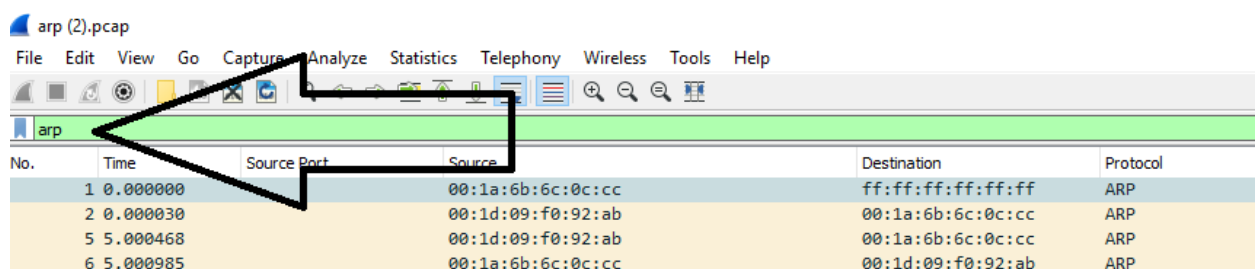
- Open Wireshark.
- Navigate to File > Open and select the [arp.pcap](#) file.

Once the file is opened, there is a feature in Wireshark that displays the OUI for each MAC address it discovers. Identifying the OUI can help determine the type of device being observed.

This feature can be turned on/off by doing the following.

- Navigate to Edit > Preferences and select Name Resolution
- From here, you can turn the Resolve MAC address feature on/off.

We will now filter for all the ARP packets, by entering arp in the filter.



In this packet capture, there are two different ARP requests and replies:

The first ARP broadcast request can be translated as "*Who has 10.10.10.1? Tell 10.10.10.2.*"

- The source host of 10.10.10.2 is making a broadcast message to everyone in the local network to see who owns 10.10.10.1.

- The request is also stating, "If you are the owner, please tell me your MAC address so I can add it to my ARP cache."
 - This way, 10.10.10.2 will know where to route the traffic for 10.10.10.1 and won't need to ask again.

No.	Time	Source Port	Source	Destination	Protocol	Length	Info
1	0.000000		00:1a:6b:6c:0c:cc	ff:ff:ff:ff:ff:ff	ARP	60	Who has 10.10.10.1? Tell 10.10.10.2
2	0.000030		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	10.10.10.1 is at 00:1d:09:f0:92:ab
5	0.000468		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	Who has 10.10.10.2? Tell 10.10.10.1
6	0.000985		00:1a:6b:6c:0c:cc	00:1d:09:f0:92:ab	ARP	60	10.10.10.2 is at 00:1a:6b:6c:0c:cc

The ARP reply to this request can be translated as "10.10.10.1 is at 00:1d:09:f0:92:ab."

- The host of 10.10.10.1 is telling 10.10.10.2 that its MAC address is 00:1d:09:f0:92:ab.

No.	Time	Source Port	Source	Destination	Protocol	Length	Info
1	0.000000		00:1a:6b:6c:0c:cc	ff:ff:ff:ff:ff:ff	ARP	60	Who has 10.10.10.1? Tell 10.10.10.2
2	0.000030		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	10.10.10.1 is at 00:1d:09:f0:92:ab
5	0.000468		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	Who has 10.10.10.2? Tell 10.10.10.1
6	0.000985		00:1a:6b:6c:0c:cc	00:1d:09:f0:92:ab	ARP	60	10.10.10.2 is at 00:1a:6b:6c:0c:cc

There is another ARP request and reply in the packet capture. While the request and reply are the same IPs but in reverse, it is still an independent request and response, unrelated to the first one.

- The source host of 10.10.10.1 is making a broadcast message to everyone in the local network to see who owns 10.10.10.2.
- 10.10.10.2 then tells 10.10.10.1 that its MAC address is 00:1a:6b:6c:0c:cc.

No.	Time	Source Port	Source	Destination	Protocol	Length	Info
1	0.000000		00:1a:6b:6c:0c:cc	ff:ff:ff:ff:ff:ff	ARP	60	Who has 10.10.10.1? Tell 10.10.10.2
2	0.000030		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	10.10.10.1 is at 00:1d:09:f0:92:ab
5	0.000468		00:1d:09:f0:92:ab	00:1a:6b:6c:0c:cc	ARP	42	Who has 10.10.10.2? Tell 10.10.10.1
6	0.000985		00:1a:6b:6c:0c:cc	00:1d:09:f0:92:ab	ARP	60	10.10.10.2 is at 00:1a:6b:6c:0c:cc

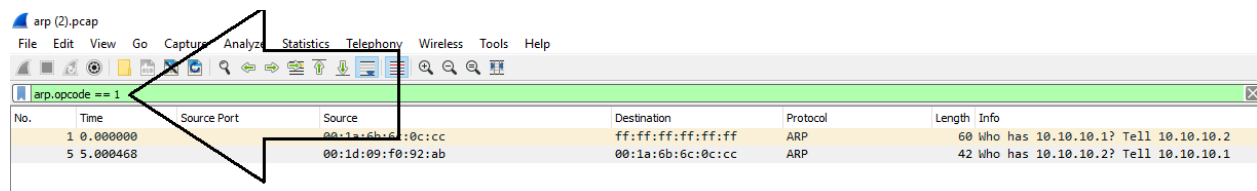
We can also filter our file to show only ARP requests or responses. Doing so can help security professionals isolate certain types of packets when there are many to analyze.

There is a field for each ARP packet called `arp.opcode` that indicates if it is an ARP request or response:

- If `arp.opcode` is equal to 1, it is a request.
- If `arp.opcode` is equal to 2, it is a response.

Run the filter `arp.opcode == 1` to show only the ARP requests.

Run the filter `arp.opcode == 2` to show only the ARP responses.



ARP Security Implications

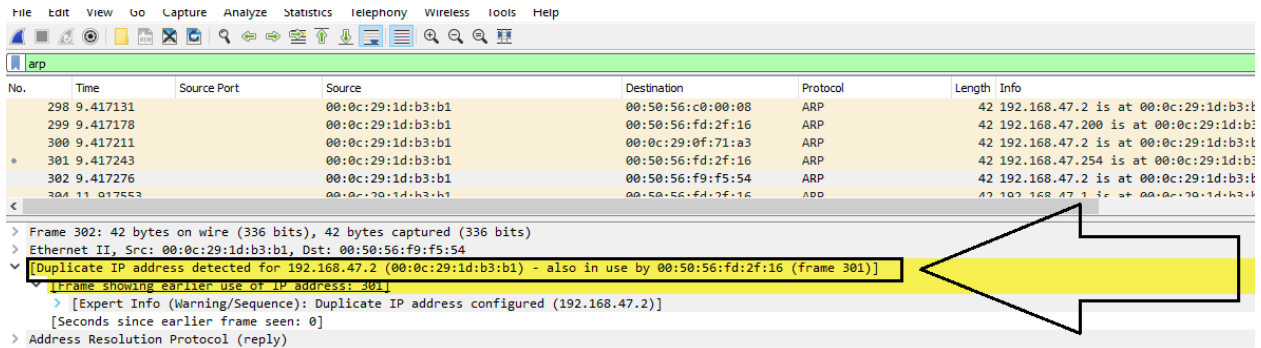
Now we know how ARP assists with routing data within a LAN, we will look at the security vulnerabilities associated with the protocol.

If a hacker has access to a LAN, they can intercept traffic on its way to the correct destination (known as *the good host*).

- The hacker can send a spoof ARP message to the LAN, directing all traffic intended for the good host to the hacker's MAC address instead.
- After the attacker sends the spoof ARP message, all traffic originally destined for the good host is intercepted by the hacker's device with the malicious MAC address.
- This attack is known as ARP cache poisoning or ARP spoofing.

This vulnerability has significant consequences, since it can be used to intercept classified or sensitive data such as usernames and passwords.

The following images visualize an ARP poisoning attack:



- The good host is 192.168.47.2 and the good host's correct MAC address is 00:50:56:fd:2f:16.
- The hacker's MAC address is 00:0c:29:1d:b3:b1. They sent a spoof ARP message, meaning all future traffic intended for the good MAC address (00:50:56:fd:2f:16) instead goes to the hacker's MAC address.
- The spoof ARP message can be translated as "192.168.47.2 is at 00:0c:29:1d:b3:b1."

Wireshark can detect that there are multiple MAC addresses being associated with a single IP address.

- Note the message from Wireshark in the screenshot: Duplicate IP address detected for 192.168.47.2 (00:0c:29:1d:b3:b1) - also in use by 00:50:56:fd:2f:16 (frame 301)
- This message from Wireshark is only a warning. No action has been taken by any device.

There are mitigation methods to protect against an ARP poisoning attack.

- A network administrator can create static ARP entries, rather than dynamic ARP entries.
 - Static ARP entries create permanent IP-address-to-MAC-address mappings in the local ARP cache.
 - Unlike the dynamic ARP entries, these cannot be changed.
 - However, it is time-consuming to manually enter and edit each IP-to-MAC mapping in the ARP cache as they are added and changed.
- Additionally, ARP spoofing detection software programs can be installed to identify and block ARP poisoning attempts. These can be expensive and often require time to install, maintain, and update.

04. Activity: Analyze ARP

- [Activity File: Analyze ARP](#)

05. Activity Review: Analyze ARP

06. ping (Layer 3: Network)

The goal of enumeration is to gain access to a particular network.

An important step of enumeration is checking if an external host is actually reachable.

- For example, Company X wants to make sure its new intranet is accessible from its offices in the United States and Japan. The intranet is used for daily employee tasks and to access employee contact information. Therefore, availability of the intranet is critical for all employees.
- To test the accessibility to the intranet, Company X has employees from the United States and Japan each send a ping request from their location to validate the intranet is available and accessible from each location.

Remember that ping is a utility for determining if a particular host is up and accepting requests.

- ping can easily be run from the command line on a Linux, Mac, or Windows machine.
- As it uses IP addresses, it works on the network layer of the OSI model (Layer 3).

When we ping a host, an Internet Control Message Protocol (ICMP) echo request is sent to a specific IP address and then waits on a reply.

- ICMP is a protocol that network devices use to send error messages and operational information about whether a requested service or host can be reached. Refer to [RFC 1122](#) for additional information.
- ICMP differs from protocols like UDP and TCP, which we'll cover later in the lesson, in that it's not usually used to exchange data between systems or by end-user applications, unless that particular application has some diagnostic tools.
- It is important to note that network devices can be online, but block ICMP requests to "hide" as a security precaution.

ping Demo

Now take a look at how to use `ping` on the command line, using the following scenario:

- You are a restaurant looking to purchase commercial beverages online. You need to check if `Pepsi.com` is working and accepting requests.

Important Note: Conduct this activity on your local machine and not the web lab. Also note this is a live network request, so there is a possibility of variances in the response.

Begin by opening up your terminal.

- There are two ways to ping a host: You can ping the domain or IP address.

First, we'll ping the domain:

- Type `ping pepsi.com`.
- Run the command. A successful response should resemble the following:

Pinging `pepsi.com` [45.60.135.51] with 32 bytes of data:

Reply from 45.60.135.51: bytes=32 time=56ms TTL=57

Reply from 45.60.135.51: bytes=32 time=403ms TTL=57

Reply from 45.60.135.51: bytes=32 time=52ms TTL=57

Reply from 45.60.135.51: bytes=32 time=36ms TTL=57

Ping statistics for 45.60.135.51:

Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),

Approximate round trip times in milli-seconds:

- Minimum = 36ms, Maximum = 403ms, Average = 136ms

End the ping by hitting `Ctrl C`.

- Press `Ctrl` then `C`. (Note: Windows stops at 4 packets by default.)

We can tell the terminal to ping the website four times by using `-c 4` in the command.

- Type `ping -c 4 pepsi.com` for Linux and Mac or type `ping -n 4 pepsi.com` for Windows.

Next, we'll ping the IP address.

- Type `ping -c 4 45.60.135.51` or `ping -n 4 45.60.135.51` for Windows.
- The response is the same, except for the top line which should resemble the following:
- Pinging 45.60.135.51 with 32 bytes of data:

Each line of the response means the following:

- Pinging pepsi.com [45.60.135.51] with 32 bytes of data:
 - This specifies the domain and the associated IP the request is being sent to, as well as the size of the packet it's sending.
- Reply from 45.60.135.51: bytes=32 time=56ms TTL=571:
 - This line is a successful response from Pepsi.com confirming the host is reachable. The response includes:
 - bytes: This is the size, in bytes, of the packet
 - time: This refers to the time it took the domain to respond, expressed in milliseconds.
 - TTL (*time to live*): This concept will be explained later in the lesson.
- Ping statistics for 45.60.135.51: Packets: Sent = 4, Received = 4, Lost = 0 (0% loss):
 - Specifies the statistics of the response. For this response, four packets were sent and four were received.
 - The "probe" packets sent from the source device are datagrams. Datagrams are basic transfer units used in connectionless communications, as opposed to TCP packets, which are used for connection-oriented communications. Refer to [RFC 1594](#) for additional info regarding datagrams.
 - We'll cover UDP and TCP in depth later on in this lesson.
- Approximate round trip times in milliseconds: Minimum = 36ms, Maximum = 403ms, Average = 136ms:
 - This specifies the statistics of the response times.

To view a failed response, use `chase.com` as an example:

Note: Many financial institutions block ICMP requests for security reasons.

- Run `ping -c 4 chase.com`.
- The failed response should resemble the following:

Pinging chase.com [80.120.169.230] with 32 bytes of data:

Request timed out.

Request timed out.

Request timed out.

Request timed out.

Ping statistics for 80.120.169.230:

Packets: Sent = 4, Received = 0, Lost = 4 (100% loss)

Syntax:

- Request timed out indicates that there were no reply messages from chase.com within the default wait time (typically one second).
- We can see that four packets were sent, but none were received, meaning there was 100% loss.

A failed response doesn't necessarily indicate that the host is down. It may simply mean that the host is not allowing requests from ICMP.

- Businesses may restrict ICMP requests for security reasons, such as preventing external parties from enumeration.
- A high volume of ICMP requests, called a ping flood, also presents a security risk that can potentially affect the server's resources and impact performance.

Security analysts are often tasked with validating hundreds or thousands of IP addresses.

For those cases, it is not efficient to ping each IP address one at a time.

- For example, a security professional works at a large e-commerce organization that uses 100 load balancers to handle the large volume of requests coming into its website.
- All the load balancers are required to be reachable. Otherwise, the website might have limited availability during peak shopping times, leading to poor customer experience.
- Making individual requests to each load balancer would be too time-consuming.

For multiple ping requests, there are utilities that can help automate the process against multiple IPs, or a range of IPs, with a single request. One such tool is `fping`, a utility that can run ping requests against multiple IPs or subnets.

07. Activity: Enumeration with ping

[Activity File: Enumeration with ping](#)

08. Activity Review: Enumeration with ping

09. Break (0:15)

10. Introduction to traceroute

In the previous section, we determined whether external hosts were reachable.

- In the example, chase.com did not respond to our ping. In this section, we'll try to find out why.

ping only indicates if a host is up or down. Security professionals often need to obtain more information to figure out why a host is not returning a successful response.

- For example:
 - Company X's employees were able to successfully ping their intranet from the United States office, but were unable to ping the exact same address from the Japan office.
 - More information is needed to understand why the intranet is not accessible from Japan.
 - Company X can better understand the issue by finding out where in the request the failure occurred.

When data travels from a source to a destination, it typically does not follow a straight path.

- Data is often redirected by many routers across various networks. Routers connect different networks so their hosts can communicate.
- Redirections of data transmissions are called hops.
- Optimal routing paths are determined based on the "shortest path," which is influenced by network topology. This is why knowledge of topology and segmentation is essential to networking.
- Despite using the "shortest path," communication between two devices can still fail, leaving network administrators unsure where the communication problem is located.
- Poor connectivity and latency issues are often due to packets being dropped along their routing paths.

Network administrators can use a command-line tool like `tracert` to troubleshoot networking communication issues between two devices and determine where the issues are in the hops.

- `tracert` shows the route taken between two systems across a network, listing all routers (hops) the connection must pass through to get to the destination.
- Network administrators can use `tracert` to identify precisely where connectivity problems occur. They can see if a problem is close to the source device or destination device or on the path it takes between devices.
- In addition to troubleshooting connectivity issues, `tracert` can be used to:
 - Display how systems are connected or map the network.
 - Generate baseline profiles of the network.
 - Diagnose network performance issues.

How `tracert` works :

- Like `ping`, `tracert` uses ICMP. However, `tracert` also shows the time taken to travel across each hop from the source to the destination.
- Each hop is queried three times to validate the accuracy of the data transmission.
- While using ICMP, the ICMP header contains a field called time to live (TTL).
 - TTL is an indicator of how long a data packet can exist in a network.
 - TTL is a decrementing hop counter. Every router that forwards the packet decrements (reduces) the TTL value by one.
 - For example, if the starting TTL value of a data packet is five, after the data travels across two routers, the TTL will drop to three.

- When the TTL count reaches zero, it sends a "time exceeded" error message back to the source address.
- This prevents data from being stuck in an infinite loop if it's unable to be delivered to the destination.

The source device sends out a sequence of User Datagram Protocol (UDP) datagrams to the destination device:

- Initially, three datagrams are sent from the source device, each with a TTL field value set to one.
- With a TTL value set to one, the datagram will timeout as soon as it hits the first router in the path. The router responds with an ICMP time exceeded message (TEM) indicating that the datagram has expired.
- From there, another three UDP messages are sent, each with a TTL value set to two, which causes the second router to return TEMs.
- This process continues until the destination device is reached.
- The visualization in the slide deck demonstrates the sequence of Host A performing a traceroute to Host B .

traceroute Demo

Now, we'll use `traceroute` on the command line to further investigate why `chase.com` isn't responding.

Note the command syntax for running `traceroute`:

- For Linux or MacOS, use `traceroute [domain name or IP address]`. For Windows, use `tracert [domain name or IP address]`.

Open a terminal in your lab environment:

- Run `traceroute chase.com`. You should see the following output:

```
Unset
$ traceroute chase.com
traceroute to chase.com (213.227.189.20), 30 hops max, 60
byte packets
 1  _gateway (10.0.2.2)  0.365 ms  0.331 ms  0.312 ms
 2  * * *
 3  * * *
```

```
4 * * *
5 * * *
...
```

traceroute on Linux uses UDP by default, which may not pass successfully from our virtual machine.

In this case, we need to run traceroute with ICMP by using the following command:

- Run `sudo traceroute -I chase.com`.
- traceroute results should look like the following:
Note: Since this is a live network ping, you may see a different result.

traceroute to chase.com (213.227.189.20), 30 hops max, 60 byte packets

```
1 _gateway (10.0.2.2) 0.177 ms 0.150 ms 0.143 ms
2 192.168.1.1 (192.168.1.1) 1.852 ms 1.788 ms 1.713 ms
3 * * *
4 012-034-056-789.res.spectrum.com (12.34.56.789) 15.567 ms 16.471 ms 16.438 ms
5 cts03sghlga-tge-3-0-0.sghl.ga.charter.com (12.34.78.231) 16.431 ms 16.893 ms 16.840 ms
6 bbr02atlnga-bue-3.atln.ga.charter.com (12.34.2.72) 22.357 ms 21.325 ms 23.787 ms
7 bbr01atlnga-tge-0-1-0-8.atln.ga.charter.com (12.34.0.132) 17.801 ms 20.431 ms 21.595 ms
8 cha-b1-link.telia.net (213.248.98.25) 21.666 ms 21.686 ms 21.678 ms
9 ash-bb2-link.telia.net (62.115.121.144) 27.860 ms 28.968 ms 28.977 ms
10 prs-bb3-link.telia.net (62.115.112.243) 120.140 ms 120.979 ms 120.976 ms
11 ffm-bb1-link.telia.net (62.115.123.12) 122.492 ms 123.387 ms 123.214 ms
12 ffm-b5-link.telia.net (62.115.114.89) 123.319 ms 123.315 ms 119.016 ms
13 ae9-1337.bbr01.anx25.fra.de.anexia-it.net (62.115.14.117) 123.272 ms 128.067 ms 128.956 ms
14 ae1-0.bbr01.anx82.fra.de.anexia-it.net (144.208.208.145) 143.023 ms 130.376 ms 134.712 ms
    • 15 ae2-0.bbr01.anx04.vie.at.anexia-it.net (144.208.208.151) 136.112 ms 131.183 ms 131.704
      ms
```

Output breakdown:

- traceroute to chase.com (213.227.189.20), 30 hops max, 60 byte packets:
 - This line indicates the website and IP address that traceroute is being run against, as well as the maximum number of hops allowed.

The results at the fourth hop, which is the first hop to our ISP's gateway after our VM NAT and local NAT hops:

- 4 012-034-056-789.res.spectrum.com (12.34.56.789) 15.567 ms 16.471 ms 16.438 ms:

- 4 indicates the first hop.
- 15.567 ms 16.471 ms 16.438 ms are the three ICMP requests that received a response in 15.567 milliseconds, 16.471 milliseconds, and 16.438 milliseconds.
- 12.34.56.789 is the first router hop located at 12.34.56.789.
- ae2-0.bbr01.anx04.vie.at.anexia-it.net (144.208.208.151) 136.112 ms 131.183 ms 131.704 ms:
 - This line is the fifteenth and last successful hop. Any additional connections didn't receive a response.
- *** means request timed out and indicates that Hop 3 timed out. No additional connections could be established.

From these traceroute results, a security or network professional knows they need to narrow their investigation to the router on Hop 8.

As a comparison, here is the traceroute for the successful request to pepsi.com:

traceroute to pepsi.com (45.60.75.51), 30 hops max, 60 byte packets

```

1 _gateway (10.0.2.2) 0.092 ms 0.064 ms 0.147 ms
2 192.168.1.1 (192.168.1.1) 1.680 ms 1.677 ms 1.604 ms
3 ***
4 012-034-056-789.res.spectrum.com (12.34.56.789) 15.729 ms 16.083 ms 16.032 ms
5 cts03sghlga-tge-3-0-0.sghl.ga.charter.com (12.34.78.231) 17.002 ms 17.000 ms 17.098 ms
6 bbr02atlnga-bue-3.atln.ga.charter.com (12.34.2.72) 18.547 ms 22.744 ms 29.947 ms
7 bbr01atlnga-tge-0-1-0-8.atln.ga.charter.com (12.34.0.132) 33.561 ms 25.719 ms 26.837 ms
8 bbr01gnvlsc-bue-800.gnvl.sc.charter.com (12.34.0.134) 23.300 ms 24.212 ms 24.269 ms
9 bbr01aldlmi-tge-0-0-0-13.aldl.mi.charter.com (12.34.0.161) 38.945 ms 39.506 ms 41.347 ms
10 prr01ashbva-bue-3.ashb.va.charter.com (12.34.3.51) 32.045 ms 32.060 ms *
11 eqix-dc2.imperva.com (206.126.237.203) 31.894 ms 31.840 ms 31.655 ms
12 45.60.75.51 (45.60.75.51) 29.500 ms 30.472 ms 26.195 ms

```

Results:

- traceroute to pepsi.com (45.60.75.51), 30 hops max, 60 byte packets:
 - This line indicates the website and IP address that the traceroute is being run against, as well as the maximum number of hops allowed.
- 4 012-034-056-789.res.spectrum.com (12.34.56.789) * 16.083 ms 16.032 ms:
 - 4 indicates the first hop.
 - * 16.083 ms 16.032 ms are the three ICMP request response times. The first did not get a timely response, while the second and third did, in 16.083 ms and 16.032 ms respectively.
 - 10.0.2.2 is typically the IP address of a local gateway (in this case, a virtual machine network gateway), the first hop.
- 12 45.60.75.51 (45.60.75.51) 29.500 ms 30.472 ms 26.195 ms:

- This is the final hop (the destination). The destination IP of pepsi.com is 45.60.75.51.
-

11. Activity: Enumeration with traceroute

[Activity File: Enumeration with traceroute](#)

12. Activity Review: Enumeration with traceroute

13. TCP is as Easy as 1–2–3

So far, we've looked at the ARP from Layer 2 and the ping and traceroute utilities from Layer 3.

Now, we'll move on to Layer 4 (transport).

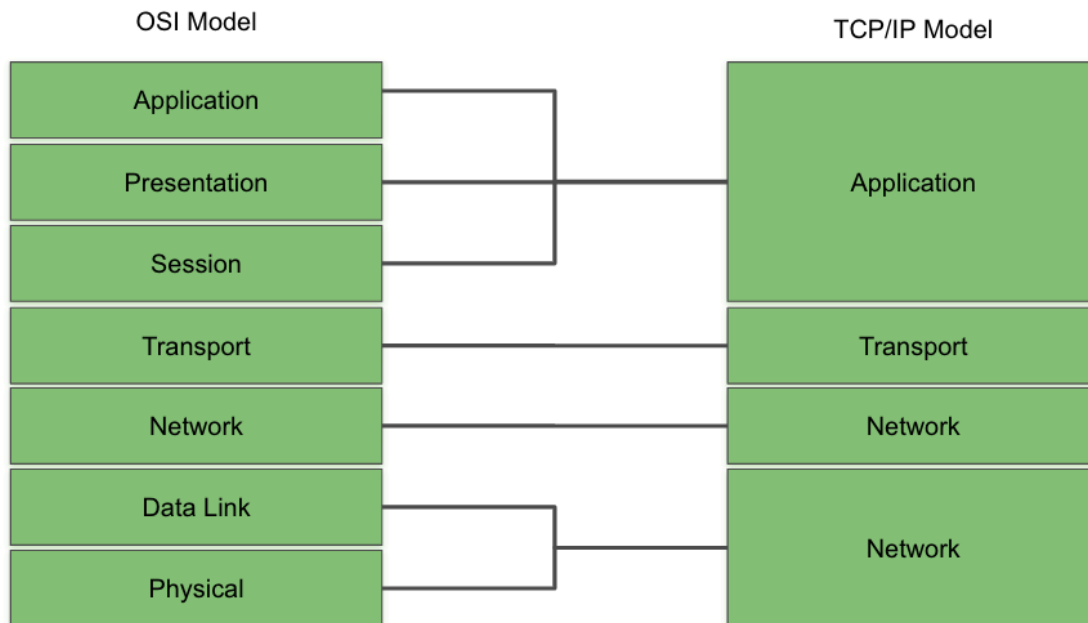
- The Transport layer is responsible for end-to-end communication over a network.
- The Transport layer takes the data from the preceding layers, breaks it up into smaller packets, and *transports* the packets to the destination.
- The recipient will reassemble these packets into a complete message.

We'll look at two Layer 4 protocols that assist with these communications: TCP and UDP.

Transmission Control Protocol (TCP)

TCP is one of the most widely used protocols for data transmission.

- TCP is part of a collection called the internet protocol suite. This suite is commonly referred to as the TCP/IP model.
 - The TCP/IP Model is similar to the OSI model and references many of the layers.
 - Review the following image to visualize how the OSI model relates to the TCP/IP model.



- TCP is considered a connection-oriented protocol, meaning that the recipient (the server) must acknowledge when it receives a request from the client.
- If the recipient doesn't acknowledge receiving the request, the sender assumes the request has not been received and will attempt to resend.
- TCP will always set up and confirm a connection before making a request.
- Connection-oriented protocols such as TCP are also considered reliable protocols because they ensure that all data is transmitted without error and in the correct order.
 - For this reason, TCP is used when all transmitted data must be received and is used with familiar protocols such as HTTP, HTTPS, FTP, SSH, and SMTP.
 - For example, you want to check your transaction history on an online banking website.
 - Use HTTPS, a protocol that runs over TCP. It ensures that all the requested data from your banking transaction history has been transmitted from the bank's web server.

- Banking customers need to trust the integrity of the data they are viewing, so it is critical that banking transaction data is complete and error-free.

Since TCP requires assurances that complete data will be transmitted between a client and server, the process must notify both sides that data has been completely transmitted.

This connection occurs through a TCP three-way-handshake.

The three-way handshake process is broken down into three steps:

1. SYN (*synchronize*): From client to server
2. SYN/ACK (*synchronize/acknowledge*): From server to client
3. ACK (*acknowledge*): From client to server

In the first, SYN, step, the client sends a SYN data packet to the server to determine if it is ready to open a connection.

In the second, SYN/ACK, step, the server acknowledges or confirms receipt of the SYN packet.

In the third, ACK, step, the client confirms receipt of the SYN/ACK packet.

Once the handshake is successfully completed, the data transmission can begin.

After the data has been transmitted, TCP uses a four-way termination process to terminate the connection.

- The four-way termination process is broken up into four steps:
 - i. FIN (*finish*): From client to server
 - ii. ACK (*acknowledge*): From server to client
 - iii. FIN (*finish*): From server to client
 - iv. ACK (*acknowledge*): From client to server
- In the first, FIN, step, the client sends a FIN data packet to the server to close the connection.
- In the second, ACK, step, the server acknowledges receipt of the FIN packet.
- In the third, FIN, step, after the server terminates the connection, it sends a FIN packet.
- In the fourth, ACK, step, the client acknowledges it has received the server's FIN packet. The TCP termination process is complete.

While TCP can ensure that all data has been transmitted in the correct order, there are some disadvantages to this protocol:

- In some cases, retransmissions (when the server resends packets because the client does not acknowledge receipt) and the ordering of packets cause delays during data transmissions.
- In cases when every single packet of data does not need to be transmitted, TCP is not used.
 - For example, while streaming a live concert on YouTube, the quality may waver because some packets are not delivered.
 - However, the video does not buffer or pause. It's better that the stream loses video quality for a moment than pausing until all the data is received at the highest quality.
- For such situations, when it's not necessary that all data reaches its destination, there is the User Datagram Protocol (UDP).

UDP

In situations for which complete data transmission is not the priority, we can use another protocol called UDP.

- UDP is better for reducing latency versus transmitting all data.
- UDP is considered a connectionless protocol, as it does not require a handshake to transmit data.
- UDP simply sends off the packets. The attitude of UDP is, "If all the packets are received, great. If not, that's okay too."

We used UDP datagrams when sending `ping` and `traceroute` requests, because if we didn't get the response we wanted, we were able to ask for it again.

- Another example of where we might use UDP is with Voice over Internet Protocol (VoIP), used for making voice calls, because we can deal with some amount of loss in these cases.

TCP Demo

Now, we will demonstrate how the TCP three-way handshake works in Wireshark:

- Log into Wireshark and open [3wayhs.pcapng file](#).

This .pcap is a depiction of the TCP three-way handshake that takes place when a website is accessed.

- Each packet represents a different step of the handshake: the packet for the SYN, for the SYN/ACK, and for the ACK.

3ways.pcapng

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter: <Ctrl-/>

No.	Time	Source Port	Source	Destination	Protocol	Length	Info
1	0.000000000	60854	10.0.2.15	93.184.216.34	TCP	74	60854 → 80 [SYN] Seq=0 Win=0 Len=0
2	0.133964079	80	93.184.216.34	10.0.2.15	TCP	60	80 → 60854 [SYN, ACK] Seq=0 Win=0 Len=0
3	0.133984150	60854	10.0.2.15	93.184.216.34	TCP	54	60854 → 80 [ACK] Seq=1 Ack=1 Win=0 Len=0
4	1.355773476	60854	10.0.2.15	93.184.216.34	HTTP	444	GET / HTTP/1.1

Select the SYN packet from the packet list and expand the TCP details from the packet details.

- The step of the handshake is indicated in a flag, which is a field in the TCP header.
- The fields are used to tell the receiver of the packet which flag is used.
- The value of the flags can either be 1 for on or 0 for off.
 - For example, in the SYN request (as shown in the following image), we can see the SYN's flag field is set to 1 (on), indicating that it is in use. All the other fields are 0, meaning only SYN is being used.

Transmission Control Protocol, Src Port: 60854, Dst Port: 80, Seq: 0, Len: 0

Source Port: 60854
Destination Port: 80
[Stream index: 0]
[TCP Segment Len: 0]
Sequence number: 0 (relative sequence number)
[Next sequence number: 0 (relative sequence number)]
Acknowledgment number: 0
1010 = Header Length: 40 bytes (10)

Flags: 0x002 (SYN)

000. = Reserved: Not set
...0 = Nonce: Not set
.... 0... = Congestion Window Reduced (CWR): Not set
.... .0.. = ECN-Echo: Not set
.... ..0. = Urgent: Not set
.... ...0 = Acknowledgment: Not set
.... 0... = Push: Not set
....0.. = Reset: Not set
>1. = Syn: Set
....0 = Fin: Not set
[TCF Flags:S.]

0000	01010010	01010100	00000000	00010010	00110101	00000010	00001000	00000000	RT...5...
0008	00100111	11111000	01000010	10100111	00001000	00000000	01000101	00000000	'B...E.
0010	00000000	00111100	01010101	10001101	01000000	00000000	01000000	00000110	<U.@.@.
0018	10100011	01000101	00001010	00000000	00000010	00001111	01011101	10111000	E....].
0020	11011000	00100010	11101101	10110110	00000000	01010000	10011011	01011110	"....P.^
0028	00101011	11011000	00000000	00000000	00000000	00000000	10100000	00000010	+.....
0030	01110010	00010000	01000010	00011000	00000000	00000000	00000010	00000100	rB.....
0038	00000101	10110100	00000100	00000010	00001000	00001010	01110000	01111101	p}

Select the SYN/ACK packet from the packet list and expand the TCP details from the packet details.

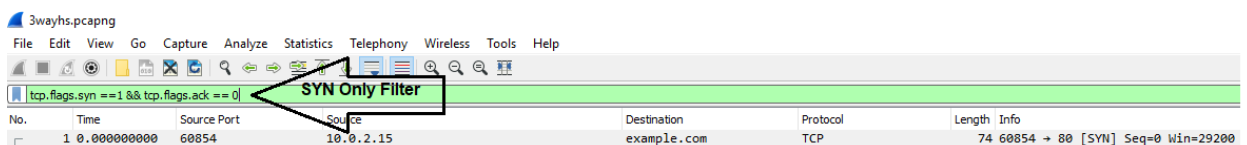
- In the SYN/ACK response (as shown in the following image), the flag fields for SYN and ACK are set to 1.

```

> Internet Protocol Version 4, Src: example.com (93.184.216.34), Dst: 10.0.2.15 (10.0.2.15)
  Transmission Control Protocol, Src Port: 80, Dst Port: 60854, Seq: 0, Ack: 1, Len: 0
    Source Port: 80
    Destination Port: 60854
    [Stream index: 0]
    [TCP Segment Len: 0]
    Sequence number: 0 (relative sequence number)
    [Next sequence number: 0 (relative sequence number)]
    Acknowledgment number: 1 (relative ack number)
    0110 .... = Header Length: 24 bytes (6)
  Flags: 0x012 (SYN, ACK)
    000. .... = Reserved: Not set
    ...0 .... = Nonce: Not set
    .... 0... = Congestion Window Reduced (CWR): Not set
    .... .0.. = ECN-Echo: Not set
    .... ..0. = Urgent: Not set
    .... ...1 = Acknowledgment: Set
    .... .... 0... = Push: Not set
    .... .... .0.. = Reset: Not set
  > .... .... .1. = Syn: Set
    .... .... ...0 = Fin: Not set
    [TCP Flags: .....A..S.]
    Window size value: 65535
    [Calculated window size: 65535]
    Checksum: 00000000
  
```

With Wireshark filters, you can easily isolate certain steps of the three-way handshake.

- The filters are based on the flag field set in the TCP header. For example:
 - To view only SYN requests with the SYN flag set to 1 and the ACK flag set to 0, run:
tcp.flags.syn == 1 && tcp.flags.ack == 0
 - To view only SYN/ACK responses with the SYN flag set to 1 and the ACK flag also set to 1, run:
tcp.flags.syn == 1 && tcp.flags.ack == 1
 - To view only ACK responses with the ACK flag set to 1 and the SYN flag set to 0, run:
tcp.flags.syn == 0 && tcp.flags.ack == 1



- To view TCP termination packets with the FIN flag set to 1, run:
tcp.flags.fin == 1

Wireshark can also easily distinguish between the client and server in these TCP handshakes:

- Remove all filters. The client IP is 10.0.2.15 and the server IP 93.184.216.34.
 - In the SYN request, the client IP is the source and the server IP is the destination.
 - In the SYN/ACK response, the client IP is the destination and the server IP is the source.
 - In the ACK response, the client IP is the source and the server IP is the destination.
 - To see the domain of the web server being accessed, you can select:
View > Name Resolution > Resolve Network Address
 - After this has been selected, the website being accessed is clearly shown as example.com.
-

14. Activity: Analyze TCP Traffic

[Activity File: Analyze TCP Traffic](#)

15. Activity Review: TCP Traffic

16. SYN Scan

In the previous class, we discussed that ports are like the "doors" to a network. It is critical for security professionals to be sure that these doors are not open to unauthorized users. For example:

- Company X recently set up a new network in its London office. A security administrator needs to ensure that the only ports open on the machines are 80

(HTTP) and 443 (HTTPS), since incoming and outgoing web traffic is allowed for its employees.

- If ports other than HTTP and HTTPS are open, there is a risk that a hacker could access the network and view confidential user and password info or impact the availability of the network by taking down a machine.

We can check for open ports on a network by sending a SYN request to every port on that network. If we receive a SYN/ACK response, the port is open.

This enumeration process of sending SYN requests to many ports on a network is called a SYN scan.

- A SYN scan is typically run by a software program that automates the sending of the SYN requests.
- If a server responds with a SYN/ACK response, the client will not complete the three-way handshake with an ACK response.
- The sole purpose of the SYN scan is to determine the current state of the ports on a network.

There are three main port states: open, closed, and filtered.

- Open means the port is accepting connections.
- Closed means the port is not accepting connections.
- Filtered means the port may be open, but a firewall or another network device is likely blocking it.

To figure out the states of the ports, we can use Wireshark to view the behavior of a conversation with the port.

- A conversation is the traffic (requests and responses) between a specific IP and port combination.
- The behavior of the conversation we would analyze is the count of packets sent in requests and responses for the specific port state.
- If we determine the behavior of these three different port states, we can quickly determine the states of all the ports when we view the summary of all conversations.

SYN scan results for different machines need to be analyzed separately, as there often are small differences in the conversation behaviors.

- The differences depend on either the program running the SYN scan or the type of server responding to the SYN requests. For example, some machines may respond with three packet replies for an open port and some may reply with one.

- The differences can also depend on the operating system of the machine being scanned or the firewall of the machine.

SYN Scan Demo

In the upcoming demonstration:

- We will be security analysts at Company X tasked with analyzing the ports from the machine recently set up in London.
- Company X is concerned that the networking team who set up the new machine left ports open, putting the company at risk of unauthorized access.
- Company X's security manager ran a SYN scan against the machine. We will analyze the results to determine which open ports can put Company X at risk.

We will use Wireshark to analyze the results of the SYN scan run against Company X.

- Log into Wireshark and pull up the [synscandemo.pcapng](#) file.

We will first filter for only TCP packets by entering TCP in the filter.

There are many SYN requests, all from the same source IP, which belongs to the security manager who ran the SYN scan. In each request, they are checking a different port.

No.	Time	Source Port	Source	Destination	Protocol	Length	Info
6	0.116622698	46945	10.0.2.15	45.33.32.156	TCP	58	46945 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
7	0.116672977	46945	10.0.2.15	45.33.32.156	TCP	54	46945 → 80 [ACK] Seq=1 Ack=1 Win=1024 Len=0
9	0.117075763	80	45.33.32.156	10.0.2.15	TCP	60	80 → 46945 [RST] Seq=1 Win=0 Len=0
13	0.409786547	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 199 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
14	0.409992895	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 22 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
15	0.410032107	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 256 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
16	0.410065415	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 330 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
17	0.410098442	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 587 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
18	0.410135047	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
19	0.410166549	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 110 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
20	0.410202886	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 113 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
21	0.410233418	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 172 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
22	0.410267548	47201	10.0.2.15	45.33.32.156	TCP	58	47201 → 888 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
23	0.477481620	22	45.33.32.156	10.0.2.15	TCP	60	22 → 47201 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0
24	0.477562400	47201	10.0.2.15	45.33.32.156	TCP	54	47201 → 22 [RST] Seq=1 Win=0 Len=0

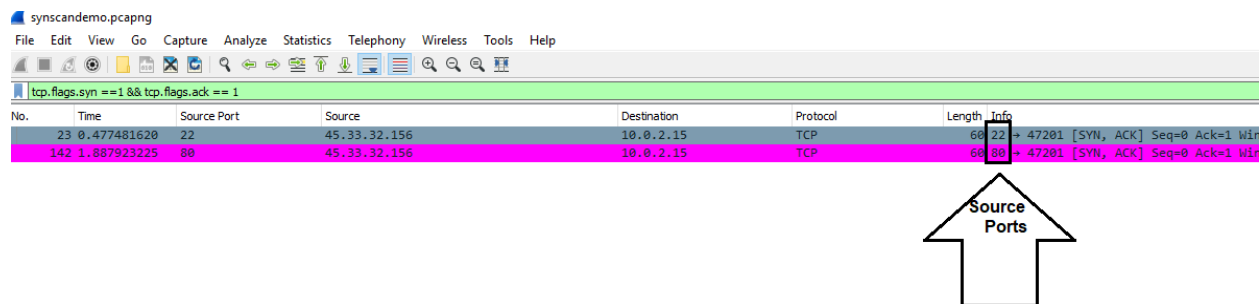
View Behavior of an Open Port

Since an open port will respond with SYN/ACK, we will use the filter from the previous exercise to look for SYN/ACK responses.

- Enter the following filter:
tcp.flags.syn == 1 && tcp.flags.ack == 1

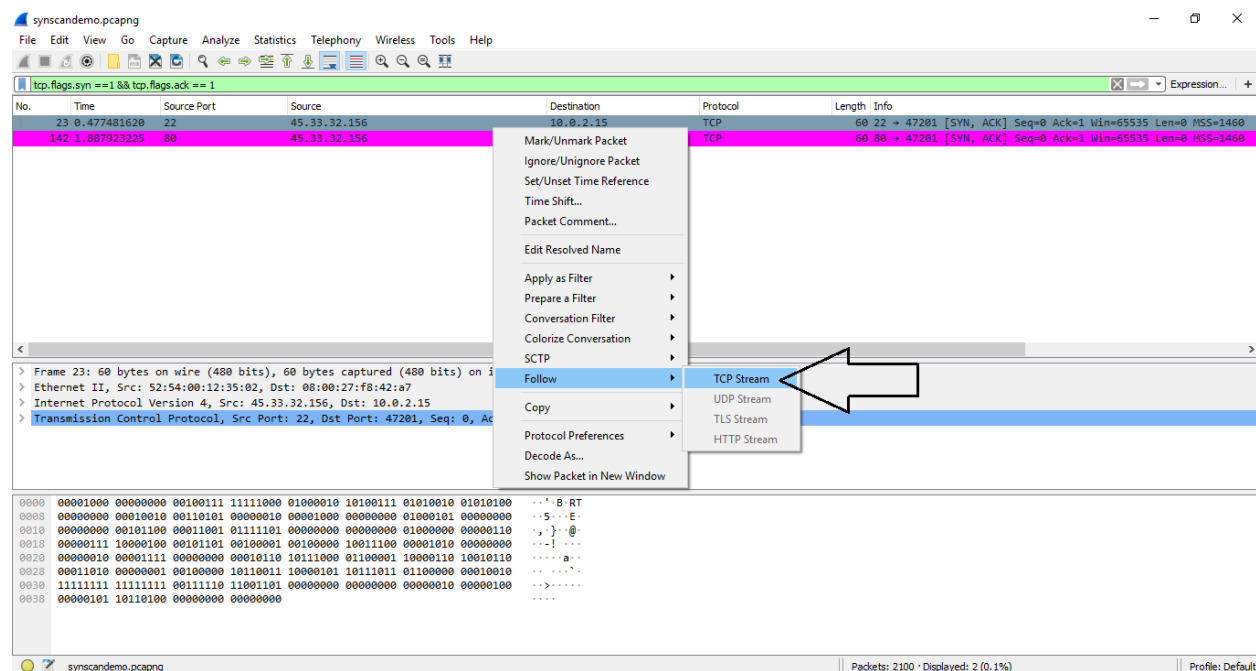
You can see the two open ports responding with a SYN/ACK are port 22 (SSH) and port 80 (HTTP). We expected port 80 (HTTP) to be open for web traffic, but we *did not* expect port 22 (SSH) to be open.

We will recommend mitigating this issue after all the ports are reviewed.



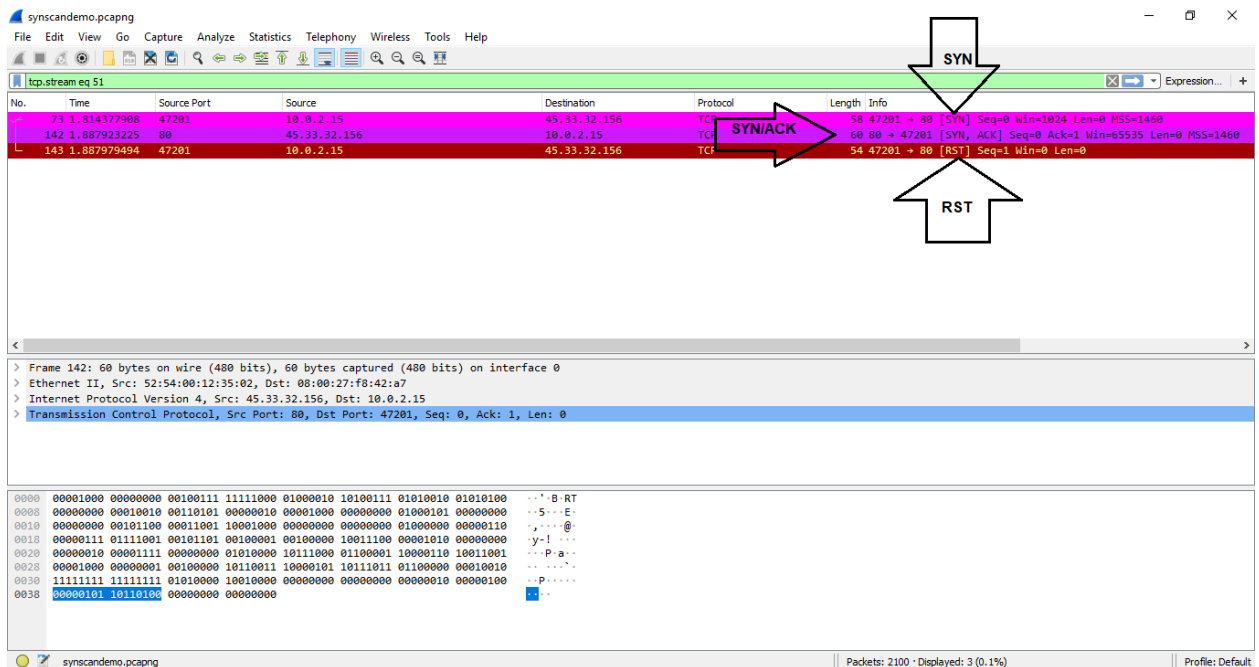
Next, we will follow the whole TCP conversation of one port to see the behavior of an open port.

- To view the conversation:
 - Right-click the port 80 packet.
 - Select Follow > TCP Stream.



In the packet capture pane, you can see the whole conversation for that specific port.

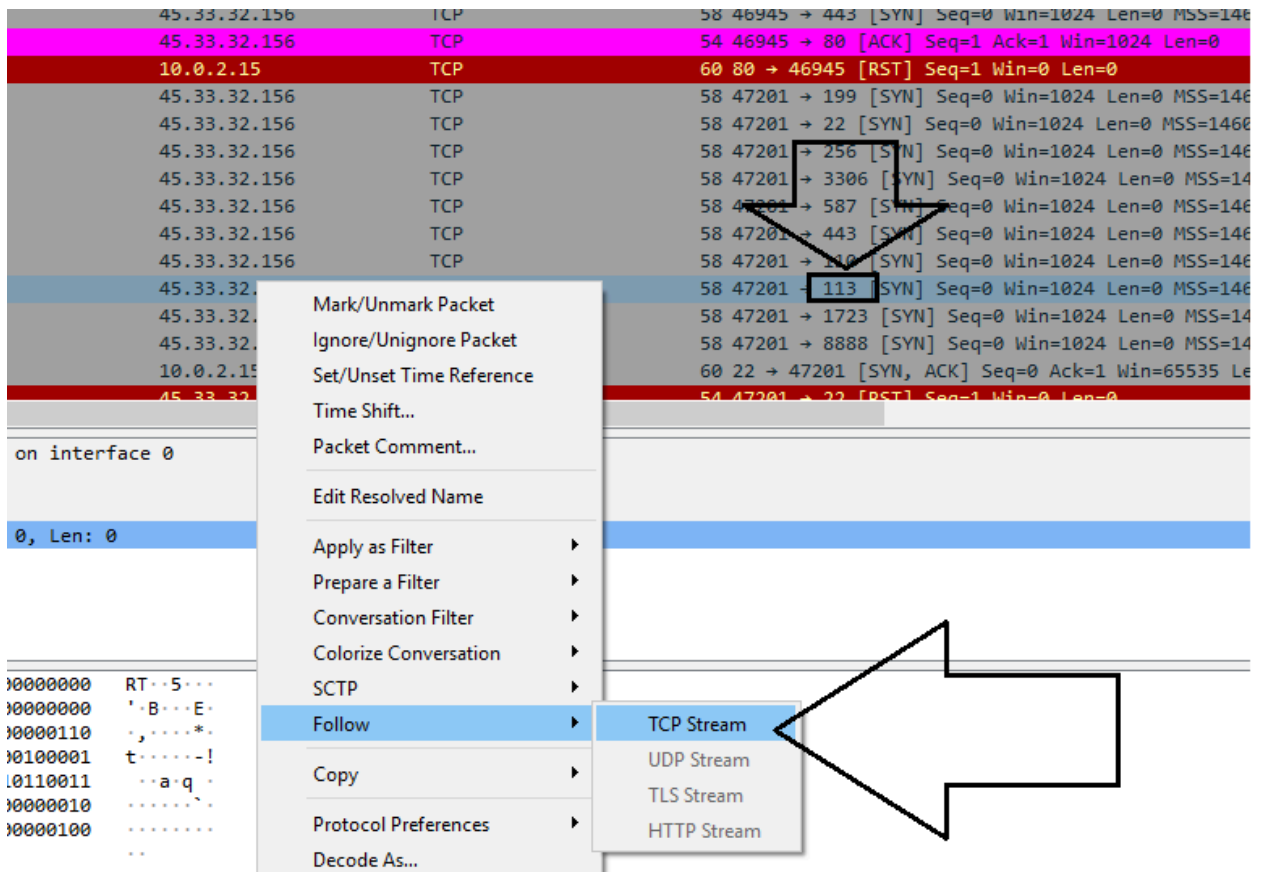
- You can see the SYN for the request to check if the port is open.
- The server responds with a SYN/ACK that the port is open.
- The client sent over a reset, or RST, message to the server. This message tells the server to terminate the connection if not already terminated.
- The important takeaway is that in this SYN scan, the behavior of an open port is three packets in a conversation.



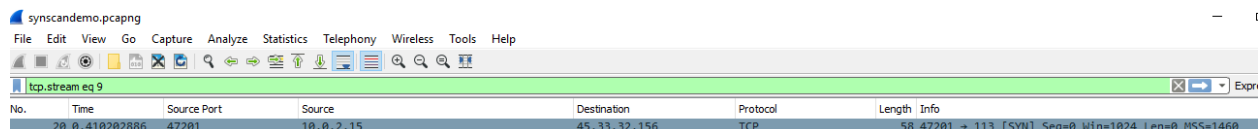
View Behavior of a Filtered Port

Servers typically do not respond with any message for filtered ports. We'll follow port 113's TCP conversation as an example.

- Select Follow > TCP Stream.



This is an example of a filtered port, where there is only a SYN request and no response of any kind from the server.

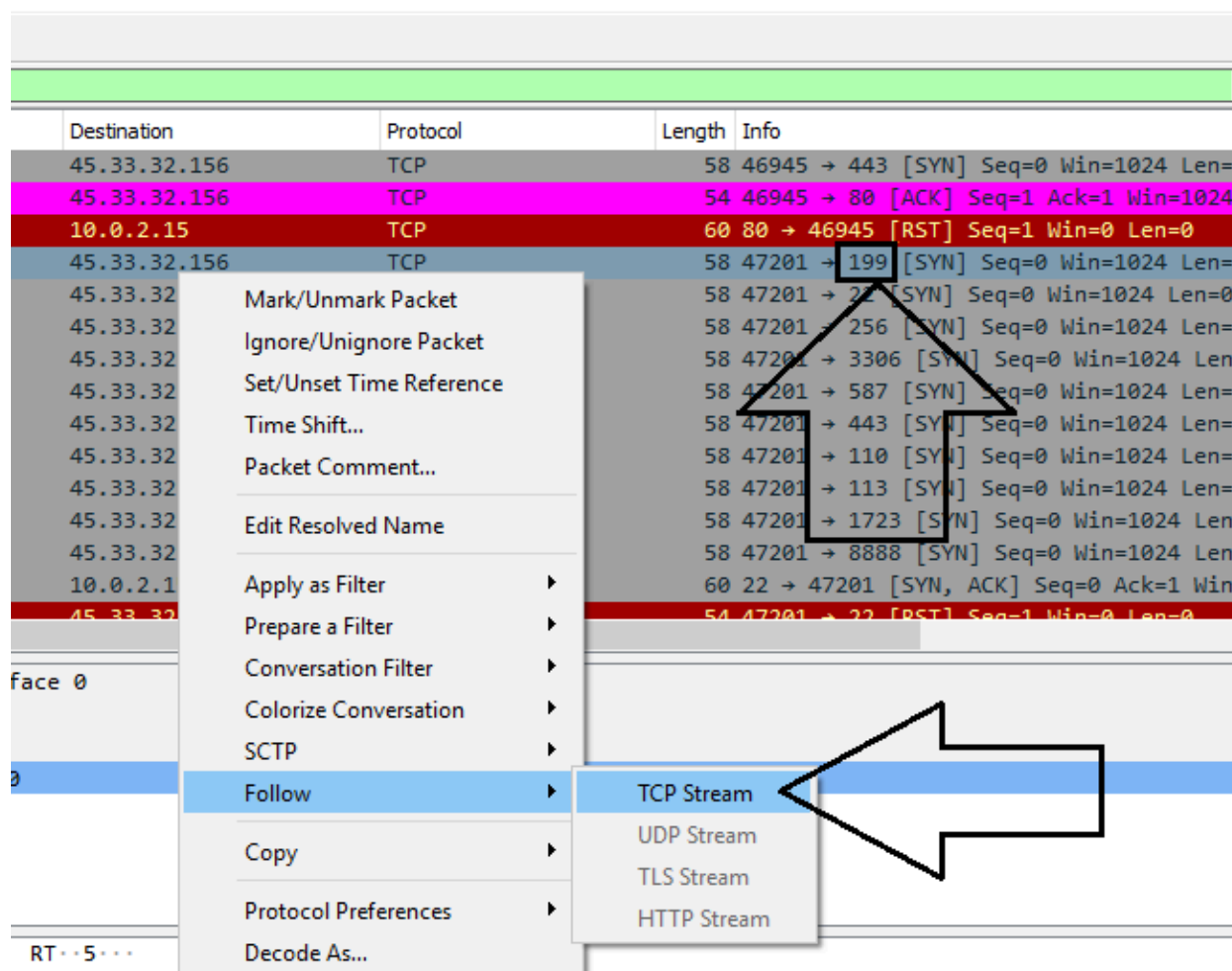


- The important takeaway is that in this SYN scan, the behavior of a closed port is one packet in a conversation.

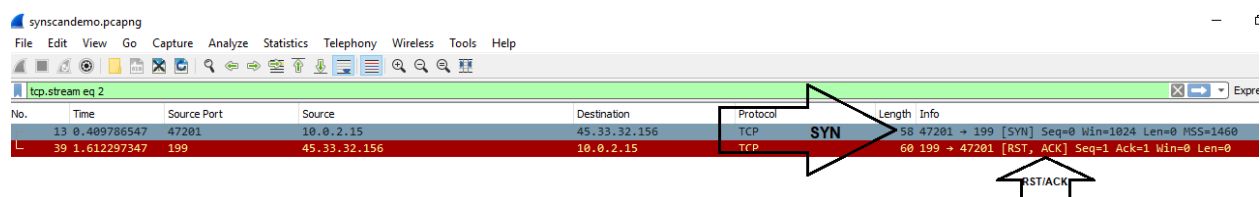
View Behavior of a Closed Port

For a closed port, the server's firewall often responds with an RST flag to indicate that they're not accepting connections. This response is configurable on the firewall's settings. We'll follow port 199's TCP conversation as an example.

- Select Follow > TCP Stream.



This is an example of a closed port, where there was only a SYN request and a response of RST/ACK from the server that it is not accepting connections.



- The important takeaway is that in this SYN scan, the behavior of a closed port is two packets in a conversation.

In summary, the SYN scan in Wireshark depicted the following behaviors for Company X's London machine's ports:

- Open ports have three packets.

- Filtered ports have one packet.
- Closed ports have two packets.

Now, we need to get the states of all the ports in the scan by viewing all the conversations:

- Select Statistics > Conversations.
- When the conversations window opens, select TCP.
- Sort by Packets Descending.

We can see the ports that have three packets (open) and the ports that have two packets (closed).

- Scroll down to see the filtered ports with one packet.

1) Select TCP

2) Sort by Packets Descending

		TCP · 1086	TCP · 2	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	R
10.0.2.15	47201	45.33.32.156	22	3	172		60	0
10.0.2.15	46945	45.33.32.156	80	3		1	60	1
10.0.2.15	46945	45.33.32.156	443	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	80	2	114	1	60	0
10.0.2.15	47201	45.33.32.156	199	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	256	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	3306	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	587	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	443	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	110	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	1723	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	8888	2	118	1	60	0
10.0.2.15	47201	45.33.32.156	554	2	118	1	60	0
10.0.2.15	47202	45.33.32.156	554	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	8888	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	1723	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	110	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	443	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	587	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	3306	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	256	2	118	1	60	1
10.0.2.15	47202	45.33.32.156	199	2	118	1	60	1
10.0.2.15	47201	45.33.32.156	993	2	118	1	60	1
10.0.2.15	47201	45.33.32.156	9999	2	118	1	60	1

We can conclude that:

- Ports 80 and 22 are open.

- The other ports are either closed or filtered, which means they are likely protected by a firewall.

Since Company X's London machine is only supposed to allow web traffic on ports 80 and 443, we must recommend that the network administrator close port 22 immediately.

Demo Summary

- All of the SYN requests going from port to port were expected. We knew a SYN scan had been run by the security manager.
- However, if a SYN scan had not been planned, this would be unusual network activity that would need to be looked into.
- If a security professional saw this activity, they would want to consider using a firewall to block the source IP from scanning their network, as a hacker could use the same SYN scan process for malicious reasons.

17. Activity: Analyze a SYN Scan

[Activity File: Analyze a SYN Scan](#)

18. Activity Review: SYN Scan